

Network Architecture Design for Multinational Bank

Complete Technical Blueprint with Explanations

Designed by Jeremiah Dighomanor

OVERVIEW: WHAT WE'RE BUILDING

We're designing a **defense-in-depth network architecture** that segments the bank's systems into security zones, controls traffic between them, and protects against both external and internal threats.

Core Principles:

- Zero Trust** - Never trust, always verify (even internal traffic)
- Least Privilege** - Users/systems only access what they absolutely need
- Defense in Depth** - Multiple layers of security (if one fails, others protect)
- Segmentation** - Divide network into isolated zones to contain breaches

PART 1: NETWORK ZONES (SEGMENTATION STRATEGY)

Think of this like designing a building with different security clearance levels. Not everyone needs access to the vault.

Zone 1: DMZ (Demilitarized Zone) - The Front Door

What it is:

A buffer zone between the internet and your internal network. Public-facing services live here.

What goes here:

- Public website (marketing site)
- Customer-facing web applications (online banking portal)
- Email gateway (receives emails from internet)
- DNS servers (external facing)
- Load balancers (distribute traffic)

Why this zone exists:

These services **MUST** talk to the internet. If they get hacked, we don't want attackers to immediately reach our internal network.

Security controls:

- External firewall (internet → DMZ)
- Internal firewall (DMZ → internal network)
- Web Application Firewall (WAF) for web apps
- DDoS protection
- Intrusion Detection System (IDS)

Network diagram:

```
Internet
  ↓
[External Firewall]
  ↓
DMZ Zone (172.16.0.0/24)
├─ Web Server 1 (172.16.0.10)
├─ Web Server 2 (172.16.0.11)
├─ Email Gateway (172.16.0.20)
└─ Load Balancer (172.16.0.5)
  ↓
[Internal Firewall]
```

IP Range: 172.16.0.0/24 (254 usable addresses)

Zone 2: Application Tier - The Business Logic

What it is:

Where your core banking applications run. This processes transactions, handles accounts, manages loans.

What goes here:

- Application servers (transaction processing)
- API gateways (for mobile apps and partners)
- Middleware (message queues, integration platforms)
- Business logic servers

Why this zone exists:

Separates user-facing systems (DMZ) from backend data (database tier). If the web server in DMZ is compromised, attackers still can't directly access databases.

Security controls:

- Application-level firewalls
- API security gateway (OAuth, rate limiting)
- Network segmentation from DMZ and data tier
- Application monitoring (SIEM integration)
- Regular vulnerability scanning

Network diagram:

```
[Internal Firewall]
  ↓
Application Tier (10.10.0.0/16)
├─ App Server Cluster (10.10.1.0/24)
│   ├── App Server 1 (10.10.1.10)
│   ├── App Server 2 (10.10.1.11)
│   └─ App Server 3 (10.10.1.12)
├─ API Gateway Cluster (10.10.2.0/24)
│   ├── API GW 1 (10.10.2.10)
│   └─ API GW 2 (10.10.2.11)
└─ Middleware (10.10.3.0/24)
```

IP Range: 10.10.0.0/16 (65,534 usable addresses)

Zone 3: Data Tier - The Vault

What it is:

Where the bank's crown jewels live. Customer data, transaction records, account information.

What goes here:

- Database servers (SQL, NoSQL)
- Data warehouses (analytics)
- Backup storage
- File servers with sensitive documents

Why this zone exists:

This is the most critical asset. It should be the MOST protected and LEAST accessible zone.

Security controls:

- Database firewalls (only allow specific app servers)
- Encryption at rest (AES-256 for all stored data)
- Database activity monitoring (DAM)
- Strict access control lists (ACLs)
- No direct internet access (air-gapped from DMZ)

Network diagram:

```
[Data Tier Firewall]
  ↓
Data Tier (10.20.0.0/16)
├─ Database Cluster (10.20.1.0/24)
│   ├── Primary DB (10.20.1.10)
│   ├── Replica DB 1 (10.20.1.11)
│   └─ Replica DB 2 (10.20.1.12)
├─ Data Warehouse (10.20.2.0/24)
└─ Backup Storage (10.20.3.0/24)
```

IP Range: 10.20.0.0/16 (65,534 usable addresses)

Critical Rule: Application tier can talk to data tier. DMZ cannot talk directly to data tier. Ever.

Zone 4: Internal Corporate Network - Employee Zone

What it is:

Where employees work. Their desktops, laptops, printers, internal apps.

What goes here:

- Employee workstations
- Internal file shares
- Printers and office devices
- HR systems, payroll systems
- Internal collaboration tools

Why this zone exists:

Employees need access to some systems but shouldn't touch production databases directly. Separating this limits damage from phishing attacks.

Security controls:

- Network Access Control (NAC) - verify devices before allowing on network
- Endpoint Detection and Response (EDR)
- Data Loss Prevention (DLP)
- Email security gateway
- Web filtering (block malicious sites)

Network diagram:

```
Internal Corporate Network (10.30.0.0/16)
├─ Employee Subnet (10.30.1.0/24)
│   ├── Desktop VLAN (10.30.1.0/25)
│   └── Laptop VLAN (10.30.1.128/25)
├─ Printers/Devices (10.30.2.0/24)
└─ Internal Apps (10.30.3.0/24)
```

IP Range: 10.30.0.0/16 (65,534 usable addresses)

Zone 5: Management Network - Admin Zone

What it is:

Isolated network for system administrators to manage infrastructure.

What goes here:

- Server management interfaces (iLO, iDRAC)
- Network device management (switches, routers)
- Security tools (SIEM, vulnerability scanners)
- Jump servers (bastion hosts for admin access)

Why this zone exists:

If an attacker compromises the regular network, they shouldn't be able to access admin tools. This is your last line of defense.

Security controls:

- Physically separate network (out-of-band management)
- Multi-factor authentication (MFA) required for all access
- Privileged Access Management (PAM) system
- Session recording (audit all admin actions)
- Whitelisted IP addresses only

Network diagram:

```
Management Network (192.168.100.0/24)
├─ Jump Server (192.168.100.10)
├─ SIEM Server (192.168.100.20)
├─ Patch Management (192.168.100.30)
└─ Admin Workstations (192.168.100.50-60)
```

IP Range: 192.168.100.0/24 (254 usable addresses)

Critical Rule: This network should be on separate physical switches if possible. Never route management traffic through production network.

Zone 6: Guest/Partner Network - The Waiting Room

What it is:

Isolated network for visitors, contractors, and third-party partners.

What goes here:

- Guest WiFi
- Contractor devices
- Partner VPN endpoints (for external vendors)

Why this zone exists:
You can't trust external devices. They might have malware. Isolating them prevents spread to corporate network.

- Security controls:**
- Captive portal (login page before internet access)
 - No access to internal resources
 - Traffic monitoring and logging
 - Bandwidth throttling
 - Time-limited access tokens

Network diagram:

```
Guest Network (172.20.0.0/24)
├─ Guest WiFi (172.20.0.0/25)
└─ Partner VPN (172.20.0.128/25)
```

IP Range: 172.20.0.0/24 (254 usable addresses)
Critical Rule: This network can only access the internet. Zero access to any internal zone.

PART 2: NETWORK SECURITY DEVICES (THE GUARDS)

1. Firewalls (The Checkpoint Guards)

What they do:
Control traffic between zones based on rules. Block unauthorized connections.

Architecture:

A. Perimeter Firewall (Internet Edge)

- **Type:** Next-Generation Firewall (NGFW)
- **Recommended:** Palo Alto PA-5220 or Fortinet FortiGate 1500D
- **Position:** Between internet and DMZ
- **Rules Example:**

```
Allow: Internet → DMZ (ports 80, 443 only)
Deny: Internet → All internal zones
Allow: DMZ → Internet (for updates)
Deny: DMZ → Internal networks (unless explicitly allowed)
```

Why NGFW not traditional firewall:

- Deep packet inspection (inspects content, not just headers)
- Application awareness (blocks Tor, BitTorrent even on port 443)
- Integrated IPS (blocks known attack patterns)
- SSL inspection (decrypts and inspects encrypted traffic)

B. Internal Segmentation Firewalls

- **Type:** Internal firewalls between zones
- **Position:** Between each zone (DMZ↔App, App↔Data, etc.)
- **Rules Example:**

```
Allow: App Tier → Data Tier (port 3306 MySQL only, specific IPs)
Deny: DMZ → Data Tier (all traffic)
Allow: Corporate → App Tier (specific apps only)
```

High Availability Setup:

```
Internet
  ↓
[Firewall 1] ↔ [Firewall 2]  (Active/Passive failover)
  ↓
DMZ
```

Why two firewalls: If one fails, the other takes over instantly. Zero downtime.

2. Intrusion Detection/Prevention System (The Security Cameras)

What they do:
Monitor network traffic for suspicious patterns. Alert on threats. Block attacks in real-time.

IDS vs IPS:

- **IDS (Intrusion Detection System):** Watches and alerts (passive)
- **IPS (Intrusion Prevention System):** Watches and blocks (active)

Recommendation: Deploy both.

Architecture:

A. Network-based IPS (NIPS)

- **Position:** Inline at critical choke points
- **Deployment points:**
 1. Between internet and perimeter firewall
 2. Between DMZ and application tier
 3. Between application tier and data tier

```
Internet → [IPS] → [Firewall] → [IPS] → DMZ → [IPS] → App Tier
```

What it detects:

- SQL injection attempts
- Port scanning
- Malware command-and-control traffic
- Data exfiltration (large outbound transfers)
- Known exploit signatures

Recommended: Cisco Firepower or Suricata (open source)

B. Network-based IDS (NIDS)

- **Position:** Passive tap (mirror port) to monitor traffic
- **Deployment:** One sensor per zone
- **Purpose:** Visibility without impacting performance

```
Network Switch
  ↓ (SPAN port - mirror traffic)
IDS Sensor → SIEM (sends alerts)
```

Why passive IDS too:

If IPS has a false positive and blocks legitimate traffic, IDS can confirm. Also, IDS sees everything without being a bottleneck.

3. Web Application Firewall (WAF) - The Bouncer for Web Apps

What it does:

Protects web applications from attacks like SQL injection, XSS, CSRF.

Position: In front of web servers in DMZ

```
Internet → [Perimeter Firewall] → [WAF] → [Web Servers]
```

What it blocks:

- SQL injection: ' OR 1=1--
- Cross-Site Scripting (XSS): <script>alert('hacked')</script>
- Path traversal: ../../etc/passwd
- Known vulnerability exploits (CVEs)

Recommended: Cloudflare WAF or AWS WAF (cloud-based) OR F5 BIG-IP ASM (on-premise)

Why cloud-based WAF is smart for banks:

- DDoS protection included
- Always updated with latest attack signatures
- Distributed globally (low latency for international customers)

Configuration example:

```
Rule 1: Block requests with "union select" (SQL injection)
Rule 2: Block requests with "<script>" tags (XSS)
Rule 3: Rate limit to 100 requests/minute per IP (prevent abuse)
Rule 4: Geo-block traffic from high-risk countries (if bank doesn't operate there)
```

4. VPN (Virtual Private Network) - The Secure Tunnel

What it does:

Allows remote employees and partners to securely connect to internal network over internet.

Types needed:

A. Remote Access VPN (For Employees)

- **Use case:** Employees working from home need to access internal systems
- **Technology:** SSL VPN (browser-based) or IPsec VPN (VPN client)
- **Recommended:** Cisco AnyConnect or OpenVPN

Architecture:

```
Employee Laptop (Home)
  ↓ (encrypted tunnel over internet)
[VPN Gateway] → [Firewall] → Internal Network
```

Security controls:

- Multi-factor authentication (MFA) required
- Endpoint compliance check (antivirus updated? OS patched?)
- Split tunneling disabled (all traffic goes through VPN)
- Session timeout after 8 hours

B. Site-to-Site VPN (For Branch Offices)

- **Use case:** Connect branch offices in different countries to headquarters
- **Technology:** IPsec VPN tunnels
- **Recommended:** Cisco ASA or pfSense

Architecture:

```
HQ Network (USA)
  ↓
[VPN Router] ↔ Internet ↔ [VPN Router]
  ↓
Branch Network (UK)
```

Why site-to-site: Branch employees access systems as if they're in HQ. Seamless experience.

5. Load Balancers - Traffic Distributors

What they do:

Distribute incoming traffic across multiple servers. Ensures high availability.

Position: In front of web servers and application servers

```
Internet → [Firewall] → [Load Balancer] → [Web Server 1]
                                           → [Web Server 2]
                                           → [Web Server 3]
```

Why this matters:

- If Web Server 1 crashes, traffic automatically goes to servers 2 and 3
- Distributes load (prevents any single server from being overwhelmed)
- Health checks (removes failed servers from rotation)

Recommended: F5 BIG-IP or HAProxy (open source) or cloud-based (AWS ELB)

Types:

A. Layer 4 Load Balancing (Transport Layer)

- Distributes based on IP address and port
- Fast but not application-aware

B. Layer 7 Load Balancing (Application Layer)

- Distributes based on HTTP headers, URLs, cookies
- Slower but smarter (can route `/api/` to API servers, `/web/` to web servers)

For banks: Use Layer 7. You need the intelligence.

6. DNS Security - Protecting Name Resolution

What it does:

Prevents DNS attacks (DNS hijacking, cache poisoning, DDoS).

Architecture:

A. Internal DNS Servers

- **Position:** Inside corporate network
- **Purpose:** Resolve internal hostnames (app-server-1.bank.local)
- **Security:** Only accessible from internal network

B. External DNS Servers

- **Position:** In DMZ
- **Purpose:** Resolve public domains (www.bank.com)
- **Security:** DDoS protection, DNSSEC enabled

Recommendation: Use split DNS

- Internal DNS for internal names
- External DNS for public names
- Never expose internal DNS to internet

DNS Security Extensions (DNSSEC):

- Cryptographically signs DNS records
- Prevents attackers from redirecting your domain to fake sites

PART 3: NETWORK MONITORING & VISIBILITY

1. SIEM (Security Information and Event Management) - The Command Center

What it does:

Collects logs from all devices (firewalls, servers, applications) and correlates them to detect threats.

Position: In management network (isolated)

What it collects:

- Firewall logs (blocked connections)
- Server logs (login attempts)
- Application logs (failed transactions)
- IDS/IPS alerts (attack attempts)
- VPN logs (who connected when)

Correlation Example:

```
Event 1: Failed login to server from IP 192.168.1.50
Event 2: Failed login to different server from same IP
Event 3: Failed login to third server from same IP
↓
SIEM Alert: "Possible brute force attack from 192.168.1.50"
```

Recommended: Splunk or IBM QRadar or ELK Stack (open source)

Why SIEM is critical:

Without it, you're blind. You have logs scattered across 1,000 devices with no way to connect the dots.

2. Network Access Control (NAC) - Device Authentication

What it does:

Verifies devices before allowing them on the network.

How it works:

1. Device connects to network
2. NAC checks: Is antivirus updated? Is OS patched? Is it a corporate device?
3. If yes → Allow full network access
4. If no → Quarantine to remediation network (limited internet, access to patch servers only)

Recommended: Cisco ISE or Aruba ClearPass

Use cases:

- Employee brings personal laptop → Gets quarantined
- Contractor device without compliance → Gets restricted access
- Server missing critical patch → Gets isolated until patched

3. Network Segmentation with VLANs

What VLANs are:

Virtual LANs. Logically separate networks on the same physical switch.

Why use VLANs:

Cost-effective segmentation without buying separate switches for every zone.

Example VLAN Design:

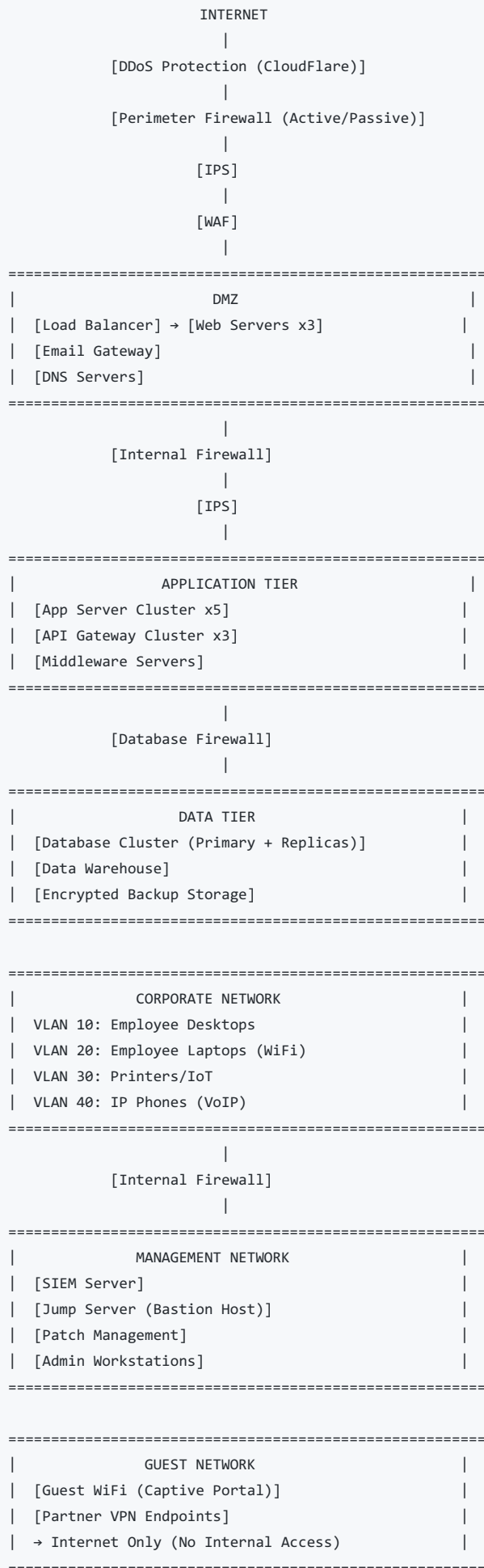
```
Switch 1
├─ VLAN 10: Employee Desktops (10.30.1.0/24)
├─ VLAN 20: Employee Laptops (10.30.2.0/24)
├─ VLAN 30: Printers (10.30.3.0/24)
└─ VLAN 40: IP Phones (10.30.4.0/24)
```

Security rule: VLANs can't talk to each other unless explicitly allowed by firewall.

Why this matters:

If printer gets hacked (it happens), attacker can't pivot to employee laptops.

PART 4: COMPLETE NETWORK ARCHITECTURE DIAGRAM



PART 5: TRAFFIC FLOW EXAMPLES (HOW IT WORKS)

Scenario 1: Customer Uses Online Banking

1. Customer (Internet)
 - DDoS Protection (checks if legitimate traffic)
 - Perimeter Firewall (allows HTTPS port 443)
 - IPS (scans for exploits)
 - WAF (checks for SQL injection, XSS)
 - Load Balancer (picks healthy web server)
 - Web Server in DMZ (serves login page)
2. Customer enters credentials
 - Web Server forwards to API Gateway in App Tier
 - API Gateway authenticates user
 - App Server queries Database in Data Tier
 - Database returns account balance
 - Response flows back through same path
 - Customer sees account balance

Security at each step:

- DDoS protection: Blocks bot traffic
 - Firewall: Blocks non-HTTPS traffic
 - IPS: Blocks known exploits
 - WAF: Blocks SQL injection in username field
 - Encryption: TLS 1.3 encrypts entire session
-

Scenario 2: Employee Accesses Internal App from Office

1. Employee laptop (Corporate Network VLAN 20)
 - NAC verifies device compliance
 - Internal Firewall (checks if employee is authorized)
 - App Server in App Tier
 - App Server queries Database in Data Tier
 - Response returns to employee laptop

Security at each step:

- NAC: Ensures laptop has updated antivirus
 - Firewall: Only allows access to apps employee needs
 - SIEM: Logs all access for audit trail
 - EDR on laptop: Monitors for malware
-

Scenario 3: Remote Employee Works from Home

1. Employee laptop (Home WiFi)
 - VPN client authenticates with MFA
 - Encrypted tunnel to VPN Gateway
 - VPN Gateway checks endpoint compliance
 - Places employee in Corporate Network VLAN 20
 - Same access as if in office

Security at each step:

- MFA: Prevents stolen password attacks
 - Endpoint check: Ensures device is compliant
 - Encryption: AES-256 encrypted VPN tunnel
 - Split tunneling disabled: All traffic goes through VPN (prevents home network attacks)
-

Scenario 4: Admin Manages Server

1. Admin workstation (Management Network)
 - Authenticates to Jump Server with MFA
 - Jump Server connects to target server
 - PAM system records entire session
 - Admin performs maintenance
 - Session recording stored in SIEM

Security at each step:

- MFA: Prevents unauthorized admin access
- Jump Server: Single point of access (easier to monitor)
- Session recording: Audit trail of all admin actions
- Whitelisted IPs: Only management network can access jump server

PART 6: WHY THIS ARCHITECTURE PROTECTS THE BANK

Against External Attacks:

DDoS Attack:

- CloudFlare absorbs attack before it reaches bank's network
- Load balancers distribute legitimate traffic
- Result: Online banking stays online

SQL Injection:

- WAF blocks malicious input
- App servers use parameterized queries (second layer of defense)
- Database firewall blocks unauthorized queries (third layer)
- Result: Database stays secure

Malware from Internet:

- Perimeter firewall blocks malicious IPs
- IPS detects malware signatures
- Endpoint protection on DMZ servers blocks execution
- Result: Malware contained in DMZ, doesn't reach internal network

Against Internal Threats:

Compromised Employee Laptop:

- Network segmentation prevents lateral movement
- EDR detects and isolates infected device
- SIEM alerts security team
- Result: Breach contained to one device

Malicious Insider:

- PAM records all privileged actions
- Database Activity Monitoring (DAM) alerts on suspicious queries
- SIEM correlates unusual access patterns
- Result: Insider detected before significant damage

Stolen Credentials:

- MFA prevents login with password alone
- NAC checks device compliance
- Anomaly detection flags login from unusual location
- Result: Attacker blocked even with valid password

PART 7: IMPLEMENTATION PRIORITIES

Phase 1: Foundation (Months 1-2)

Priority: Get basic security in place ASAP

1. Deploy perimeter firewall
2. Set up basic network segmentation (DMZ, Internal, Management)
3. Implement VPN for remote access
4. Deploy endpoint protection on all devices
5. Set up basic SIEM (even if just collecting logs)

Why start here: These are your "must-haves." Can't operate without them.

Phase 2: Enhanced Protection (Months 3-4)

Priority: Add detection and response capabilities

1. Deploy IPS at critical points
2. Implement WAF for web applications
3. Set up Network Access Control (NAC)
4. Configure SIEM correlation rules
5. Deploy database firewall

Why now: Foundation is secure. Now add visibility and automated response.

Phase 3: Advanced Capabilities (Months 5-6)

Priority: Optimize and add advanced features

1. Implement full network segmentation with VLANs
2. Deploy endpoint detection and response (EDR)
3. Set up privileged access management (PAM)
4. Configure advanced SIEM analytics (machine learning)
5. Implement data loss prevention (DLP)

Why later: These are optimizations. Nice to have but not critical day one.

Phase 4: Continuous Improvement (Ongoing)

Priority: Stay ahead of threats

1. Regular penetration testing
2. Firewall rule reviews
3. Network architecture audits
4. Threat hunting exercises
5. Tabletop exercises with security team

Why ongoing: Security is never "done." Threats evolve daily.

PART 8: COST BREAKDOWN (BALLPARK ESTIMATES)

Hardware & Software (One-time):

- Firewalls (HA pair): \$100K - \$200K
- IPS/IDS: \$50K - \$100K
- Load Balancers: \$50K - \$100K
- VPN Gateway: \$20K - \$50K
- Network Switches: \$100K - \$200K
- WAF (appliance): \$50K - \$100K
- **Total: \$370K - \$750K**

OR Cloud-Based Alternative:

- Firewall-as-a-Service: \$5K/month
- WAF (CloudFlare): \$2K/month
- IPS (Cloud): \$3K/month
- **Total: \$10K/month = \$120K/year**

Licenses (Annual):

- Firewall subscriptions: \$30K/year
- SIEM: \$50K - \$150K/year
- Endpoint protection: \$50/endpoint/year × 1000 = \$50K/year
- **Total: \$130K - \$230K/year**

Staffing:

- Network Security Engineer: \$120K/year
- SOC Analyst (3 shifts): \$180K/year
- Security Architect: \$150K/year
- **Total: \$450K/year**

Grand Total Year 1: \$950K - \$1.43M (hardware) OR \$700K - \$900K (cloud)

PART 9: SUCCESS METRICS

How to prove this architecture works?

Technical Metrics:

- **Mean Time to Detect (MTTD):** Average time to detect security incident → Target: < 15 minutes
- **Mean Time to Respond (MTTR):** Average time to contain incident → Target: < 1 hour
- **False Positive Rate:** IPS alerts that aren't real threats → Target: < 5%
- **Network Uptime:** Availability of critical systems → Target: 99.99% (52 minutes downtime/year)

Security Metrics:

- **Blocked Attacks:** Number of malicious connections blocked → Track trend over time
- **Successful Breaches:** Incidents where attackers gained access → Target: 0
- **Patch Compliance:** Percentage of systems with current patches → Target: 95%+
- **Vulnerability Scan Score:** Number of critical vulnerabilities → Target: 0 critical, < 10 high

Compliance Metrics:

- **Audit Findings:** Issues found during compliance audits → Target: 0 critical findings
- **Policy Violations:** Employees bypassing security controls → Track and train
- **Incident Response Drills:** Tabletop exercises completed → Target: 2 per year

THE BOTTOM LINE

This network architecture protects the bank by:

1. **Preventing attacks** (firewalls, IPS, WAF)
2. **Detecting breaches** (SIEM, IDS, monitoring)
3. **Containing damage** (segmentation, isolation)
4. **Enabling response** (visibility, logging, forensics)

Every design decision traces back to protecting Confidentiality, Integrity, and Availability of the bank's systems.